

Assignment 1: Scenario-Based ISMS Implementation

Course: ISO/IEC 27001 Lead Implementer

Scenario: MediCloud Health Solutions

Prepared by: Lead Implementer OLANIPEKUN ADEBUKOLA

Task 1: Scope Statement (Clause 4.3)

ISMS Scope Statement - MediCloud Health Solutions

The Information Security Management System (ISMS) of MediCloud Health Solutions covers the design, development, hosting, delivery, and support of the MediCloud Electronic Health Record (EHR) SaaS platform provided to small and medium-sized dental clinics.

In Scope:

- **Organizational units:** Software Development function (30 remote developers), Customer Support function (10 staff, Manchester office), and Executive Management (5 executives), including all information security governance, risk management, and operational activities they perform in support of the EHR service.
- **Systems and applications:** The MediCloud EHR application (source code, application architecture, APIs), associated databases containing patient health information (PHI) and clinic data, CI/CD pipelines, and all supporting infrastructure hosted on Microsoft Azure (compute, storage, networking, identity, and cloud-native security services) within MediCloud's Azure tenant(s)/subscription(s).
- **Physical locations:** The Manchester office (customer support operations, including local network infrastructure, workstations, and physical access controls).
- **Logical/remote locations:** Remote working environments used by the 30 distributed software developers, covering endpoint devices, remote access mechanisms (VPN/Zero Trust access), and cloud-based development tools, to the extent they connect to or process information within the ISMS scope.
- **Supporting business processes:** HR security processes (onboarding/offboarding, background checks, security awareness training), supplier/vendor management (including the Azure cloud service relationship), incident management, business continuity, and change management as they relate to the EHR service and the information assets above.

Exclusions:

- Physical premises of Microsoft Azure data centers are excluded from direct ISMS control, as they fall under Microsoft's own ISO/IEC 27001, SOC 2, and other certifications; MediCloud manages this relationship through supplier/cloud service controls (Annex A 5.23, 5.19-5.22) rather than direct physical/operational control.
- Personal, non-corporate devices and home network infrastructure of remote employees are excluded from physical security clauses (Annex A 7.x) but remain in scope for logical/technical controls (endpoint protection, MFA, encryption, remote access policy) applicable to the information they access.
- Corporate functions with no access to the EHR platform or associated data (e.g., purely administrative/back-office finance activities not involving customer or patient data) are excluded, where such separation can be demonstrated.
- Marketing website and public-facing informational content not connected to the production EHR environment are excluded.

Interfaces and Dependencies:

The ISMS scope explicitly recognizes dependencies on Microsoft Azure as a critical cloud service provider, third-party payment processors (if applicable), and clinic-side users (dental clinic staff) as external parties whose actions can affect the confidentiality, integrity, and availability of information within scope. These dependencies are managed via Annex A 5.19-5.23 (supplier relationships and cloud services).

Task 2: Preliminary Information Security Risk Assessment

#	CIA Element	Risk Scenario	Potential Impact	Annex A Control(s)
1	Confidentiality	A misconfigured Azure Blob Storage container or database access policy exposes patient health records (PHI) to unauthorized internet access, or a developer with excessive privileges accesses production patient data without a legitimate business need.	Customer impact: Breach of patient confidentiality for dental clinics' patients, reputational damage to clinics, potential regulatory/legal liability under health data protection laws (e.g., UK GDPR, HIPAA if US clients). Organizational impact: Loss of the prospective large dental chain contract, regulatory fines, loss of certification, reputational damage that undermines MediCloud's core value proposition.	5.15 (Access control), 5.18 (Access rights), 8.3 (Information access restriction), 8.24 (Use of cryptography), 5.10 (Acceptable use of assets)
2	Integrity	A software developer inadvertently (or a malicious insider deliberately) pushes a faulty code change directly to production without peer review or testing, corrupting patient records or altering clinical data (e.g., medication history, treatment notes) within the EHR system.	Customer impact: Clinicians rely on inaccurate patient data, potentially leading to incorrect clinical decisions; loss of trust in data reliability. Organizational impact: Legal/clinical liability exposure, costly data recovery efforts, damage to reputation as a reliable clinical data platform.	8.28 (Secure coding), 8.29 (Security testing in development and acceptance), 8.32 (Change management), 5.3 (Segregation of duties)
3	Availability	A Distributed Denial of Service (DDoS) attack or an Azure regional outage takes the EHR platform offline during clinic business hours, preventing dental clinics from accessing patient records needed for scheduled appointments and treatments.	Customer impact: Dental clinics cannot operate — appointments delayed/cancelled, inability to access critical patient history during treatment, direct financial and reputational harm to clinic customers. Organizational impact: Breach of SLAs, contractual penalties, loss	5.29 (Information security during disruption), 5.30 (ICT readiness for business continuity), 8.14 (Redundancy of information processing facilities), 8.6 (Capacity management)

#	CIA Element	Risk Scenario	Potential Impact	Annex A Control(s)
			of client trust, and direct threat to the prospective large dental chain contract.	

Task 3: Statement of Applicability (SoA)

Control ID	Control Description	Included? (Y/N)	Justification
5.23	Information security for use of cloud services	Y	MediCloud's entire EHR platform is hosted on Microsoft Azure, making cloud service usage central to the ISMS scope. This control is essential to formally define processes for acquiring, using, managing, and exiting cloud services, including due diligence on Azure's own security certifications, defining shared responsibility boundaries, and monitoring cloud configuration.
6.7	Remote working	Y	30 of MediCloud's 45 employees (the entire software development function) work remotely on a permanent basis. This control is mandatory to establish policies covering secure remote access (VPN/Zero Trust), endpoint security requirements, physical security of remote workspaces, and acceptable use while working outside the office.
7.1	Physical security perimeters	Y (partial scope)	While 30 developers work remotely (addressed instead via 6.7 and technical controls), the Manchester office housing 10 customer support staff and company assets requires a defined physical security perimeter. This control is included specifically for the Manchester office; it is not extended to employees' private residences, which are excluded from physical perimeter requirements.
8.28	Secure coding	Y	MediCloud is fundamentally a software development organization producing the EHR application that stores and processes sensitive patient health data. Secure coding practices are essential to prevent vulnerabilities that could compromise the confidentiality and integrity risks identified in Task 2. Excluding this control would leave the core product without a systematic security development lifecycle.

Task 4: Corrective Action Plan (Clause 10.2 - Nonconformity and Corrective Action)

Incident Summary

A Manchester-based customer support agent fell for a phishing email; the attacker attempted to log in with the harvested credentials but was blocked by MFA. Investigation revealed the agent had never completed mandatory security awareness training.

1. Immediate Action (Containment / Correction)

- **Compromised account:** Treat the account as potentially compromised despite the failed login. Immediately force a password reset for the affected account, revoke and reissue MFA tokens/session credentials, and review account activity logs and any active sessions for signs of successful access (even partial) before the MFA block occurred.
- **Broader containment:** Search email systems for other recipients of the same phishing email and confirm no other accounts were compromised; block the sender domain/IP and update email security filtering (e.g., DMARC/DKIM/anti-phishing rules) to prevent recurrence.
- **Employee:** Treat this as a process failure rather than solely individual fault. The employee should receive immediate, targeted refresher guidance on recognizing phishing (not punitive action), and the incident should be logged formally in the incident register per the organization's incident management procedure (Annex A 5.24-5.28), including timeline, actions taken, and evidence that MFA controls performed as designed.
- **Reporting:** Log this as a formal nonconformity against the ISMS requirement for mandatory security awareness training (Clause 7.2/7.3, Annex A 6.3), since the training program's intended outcome (all staff trained) was not achieved.

2. Root Cause Analysis

Plausible process failure: MediCloud's security awareness training rollout relied on a manual, one-time enrollment process (e.g., an HR administrator manually adding new hires to a training platform) rather than an automated trigger integrated with the onboarding workflow. The support agent in question was hired or transferred into their role during a period of transition (e.g., between HR staff, or during a batch onboarding of multiple new hires) and was inadvertently omitted from the training assignment list. There was no tracking dashboard or compliance report that would have flagged the agent as “not yet trained,” and no periodic reconciliation between the HR employee roster and the training platform's completion records existed to catch such gaps. This represents a breakdown in the HR security process (Annex A 6.3) integration with onboarding (Annex A 6.1/6.2), rather than an isolated individual oversight.

3. Corrective Action (Systemic Change)

To address the root cause and prevent recurrence, the following systemic corrective actions will be implemented:

- **Automate training assignment:** Integrate the security awareness training platform directly with the HR onboarding system (or HRIS) so that any new employee, contractor, or role change automatically and immediately triggers enrollment in mandatory training as part of Day 1 onboarding; removing dependency on manual administrative steps.
- **Mandatory completion gating:** Configure access provisioning so that full system access (or at minimum, access to production/customer data systems) is contingent on completion of initial security awareness training within a defined grace period (e.g., 5 business days), enforced technically where feasible (e.g., conditional access policies).

- **Compliance monitoring and reconciliation:** Establish a monthly (or more frequent) reconciliation report comparing the full active employee roster against the training platform's completion records, with escalation to HR and the CISO/Lead Implementer for any gaps identified.
- **Management review input:** Add training completion status as a standing metric reviewed at ISMS management reviews (Clause 9.3) and internal audits (Clause 9.2), ensuring ongoing visibility rather than one-time remediation.
- **Verification of effectiveness:** As required by Clause 10.2(f)/(g), review the effectiveness of this corrective action after the next reconciliation cycle and during the next internal audit, confirming that 100% of active employees show current training completion records, and close the nonconformity only once evidence confirms the corrective action has eliminated the root cause.